

Cyber Threat Intelligence

Executive Briefing

Report Date: July 11, 2026

Generated: 2026-07-11 20:26 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
2	5	6	0	20

2. Executive Summary

As of July 11, 2026, the security operations center has concluded an analysis of 20 identified vulnerabilities, resulting in a severity distribution of 2 Critical, 5 High, 6 Medium, and 0 Low findings. Our current organizational risk posture is evaluated as 'Critical' under the CVSS v3.1 framework, necessitated by the presence of multiple exploitable flaws that could facilitate remote system compromise and unauthorized data manipulation. The primary concern is CVE-2026-52778, Remote Code Execution in YesWiki Formula Calculator, which mandates immediate attention due to the triviality of execution and the potential for complete system takeover. We maintain a high-alert response posture, requiring the immediate suspension of affected services and the prioritization of patch deployment across all internal environments. It is imperative that all remediation activities be concluded within the defined 24-hour window to mitigate imminent exploitation risks.

3. Critical Action List

- CVE-2026-52778: Immediately isolate all affected YesWiki instances from the production network and deploy the emergency vendor patch within 24 hours.
- CVE-2026-52766: Disable the 'erasespamedcomments' template functionality across all YesWiki deployments and enforce strict access controls within 24 hours.
- CVE-2026-52775: Implement parameterized query sanitization for the ReactionManager component and initiate a full database integrity audit within 48 hours.
- CVE-2026-52771: Restrict access to the ApiController page deletion interface to administrative accounts only and deploy the requisite input validation patch within 48 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
--------	--------------	------	----------	---------	-----

CVE-2026-52778	Remote Code Execution in YesWiki ...	9.8	Critical	88/100	CWE-94
CVE-2026-52766	Unauthenticated Page Deletion in ...	9.1	Critical	82/100	CWE-276
CVE-2026-52777	PHP Object Injection in YesWiki B...	8.8	Unknown	79/100	CWE-352
CVE-2026-52775	Authenticated SQL Injection in Ye...	8.8	High	79/100	CWE-89
CVE-2026-52771	Second-Order SQL Injection in Yes...	8.3	High	75/100	CWE-89
CVE-2026-52769	Unauthenticated SSRF in YesWiki A...	8.3	High	75/100	CWE-918
CVE-2026-52767	ActivityPub Signature Verificatio...	8.2	High	74/100	CWE-347
CVE-2026-53932	OS Command Injection in laravel-b...	8.0	Unknown	72/100	CWE-77
CVE-2026-52770	SQL Injection in YesWiki Bazar AP...	7.5	High	68/100	CWE-89
CVE-2026-53727	SSRF and Local File Disclosure in...	7.5	Unknown	68/100	CWE-918
CVE-2026-52762	Server-Side Template Injection in...	7.2	Unknown	65/100	CWE-1336
CVE-2026-53637	Unauthorized Modification of Comp...	6.5	Medium	59/100	CWE-672
CVE-2026-52763	SQL Injection in YesWiki Recent C...	6.5	Medium	59/100	CWE-89
CVE-2026-53769	Missing Upload Authorization in A...	6.5	Medium	59/100	CWE-862
CVE-2026-53602	Non-Durable Host Revocation in Ne...	9.1	Unknown	59/100	CWE-613
CVE-2026-52774	Reflected Cross-Site Scripting in...	6.1	Medium	55/100	CWE-80
CVE-2026-52773	Reflected XSS in YesWiki Revision...	6.1	Medium	55/100	CWE-80
CVE-2026-52772	Stored Cross-Site Scripting in Ye...	5.5	Unknown	50/100	CWE-79
CVE-2026-53760	Cross-Site Request Forgery in Adm...	5.2	Unknown	47/100	CWE-352
CVE-2026-53638	Payment Method Restriction Bypass...	4.3	Medium	39/100	CWE-863

5. Detailed Vulnerability Findings

CVE-2026-52778

Finding: Remote Code Execution in YesWiki Formula Calculator

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-94

Score Provenance: Unverified

MITRE ATT&CK: T1210, T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The YesWiki Formula Calculator utilizes an unsafe eval() call when processing user-supplied mathematical equations. The application fails to properly sanitize or restrict inputs parsed by the calculation engine, allowing arbitrary code execution within the server context. An unauthenticated remote attacker can exploit this weakness to compromise the

entire system and cause a total denial of service.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies the YesWiki Formula Calculator endpoint. The attacker sends a crafted HTTP request containing system commands wrapped inside a formula payload processed by the calculator. The server-side calculator passes the input directly into a PHP eval call without input sanitization. This executes the specified commands under the privileges of the web server process, leading to complete host compromise.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52778>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52778>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52778>

CVE-2026-52766

Finding: Unauthenticated Page Deletion in YesWiki

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 82/100 | CWE: CWE-276

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1565, T1485

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

YesWiki contains an improper privilege management vulnerability when processing the erasespamedcomments template action. The application allows public, unauthenticated access to this deletion action without verifying administrative privileges. This enables remote attackers to delete arbitrary wiki pages and comments, causing extensive data loss and site defacement.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies a page utilizing or allowing the execution of the erasespamedcomments action macro. The attacker sends a request targeting this action and specifies arbitrary target page identifiers inside the parameters. The server processes the deletion action directly without validating that the actor possesses administrative credentials. This results in the immediate and permanent deletion of the selected pages and comments from the database.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52766>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52766>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52766>

CVE-2026-52777

Finding: PHP Object Injection in YesWiki BazarImportAction

CVSS v3.1 Score: 8.8 | Severity: Unknown | Urgency Score: 79/100 | CWE: CWE-352

Score Provenance: Unverified
MITRE ATT&CK: T1059.003, T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

YesWiki is vulnerable to an authenticated PHP Object Injection vulnerability in the BazarImportAction class. The application passes untrusted, user-supplied data directly into the unserialize() function without safe validation. This enables an authenticated attacker to inject arbitrary PHP objects, potentially leading to remote code execution and unauthorized data access.

Proof of Concept (PoC):

An authenticated attacker with access to the Bazar import functionality crafts a serialized PHP payload containing a malicious gadget chain. The attacker submits this payload via the import parameter processed by the BazarImportAction class. The application executes PHP's unserialize function on the untrusted string without verification. This triggers magic methods within the gadget chain to execute arbitrary system commands on the server.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52777>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52777>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52777>

CVE-2026-52775

Finding: Authenticated SQL Injection in YesWiki ReactionManager

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 79/100 | CWE: CWE-89

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

YesWiki is vulnerable to an authenticated SQL injection flaw within its ReactionManager component. The database queries constructed by the reaction handler fail to sanitize user-controlled parameters before execution. This allows an authenticated attacker to execute arbitrary SQL commands to read, modify, or delete sensitive data within the database.

Proof of Concept (PoC):

An authenticated user targets the reaction submission feature handled by the ReactionManager class. The attacker submits a POST request containing SQL syntax inside the reaction identifier parameter. The server integrates the unescaped parameter directly into a dynamic SQL query string. This enables the attacker to manipulate the query execution flow and extract administrative password hashes from the database.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52775>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52775>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52775>

CVE-2026-52771

Finding: Second-Order SQL Injection in YesWiki Page Delete API

CVSS v3.1 Score: 8.3 | Severity: High | Urgency Score: 75/100 | CWE: CWE-89

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

YesWiki contains a second-order SQL injection vulnerability in its page deletion interface handled by ApiController::deletePage. The application retrieves page tags stored in the database and inserts them into dynamic deletion queries without prior sanitization or parameterization. This allows an attacker who previously registered a malicious page tag to execute unauthorized database queries when that page is deleted.

Proof of Concept (PoC):

An authenticated attacker registers a wiki page using a page tag crafted with malicious SQL injection commands. At a later point, an administrator or automated system triggers the page deletion API via ApiController::deletePage. The database retrieves the stored page tag and interpolates it directly into an unparameterized SQL deletion query. This executes the nested payload, granting the attacker the ability to dump sensitive database tables.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52771>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52771>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52771>

CVE-2026-52769

Finding: Unauthenticated SSRF in YesWiki ActivityPub

CVSS v3.1 Score: 8.3 | Severity: High | Urgency Score: 75/100 | CWE: CWE-918

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190, T1133

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:L/A:L

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	Low

Description:

YesWiki features an unauthenticated Server-Side Request Forgery vulnerability within its ActivityPub signature verification system. The server parses the Signature.keyId header value and immediately attempts to fetch the public key resource from the specified URL without domain whitelisting. This allows a remote attacker to force the server to perform HTTP requests to arbitrary internal or external targets.

Proof of Concept (PoC):

An unauthenticated attacker crafts an ActivityPub federation request with a custom Signature HTTP header. The attacker configures the keyId parameter to point to a private internal network endpoint, such as http://192.168.1.1/admin. The YesWiki server receives the request and immediately initiates an outbound HTTP request to retrieve the key from that internal URL. This allows the attacker to probe the internal network infrastructure and bypass network firewalls.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52769>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52769>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52769>

CVE-2026-52767

Finding: ActivityPub Signature Verification Bypass in YesWiki

CVSS v3.1 Score: 8.2 | Severity: High | Urgency Score: 74/100 | CWE: CWE-347

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1556

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:L

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	High	Availability Impact	Low

Description:

YesWiki contains a cryptographic signature verification bypass in its ActivityPub integration due to improper handling of error returns. The authentication logic utilizes !openssl_verify(...) which incorrectly treats a return value of -1 as a successful signature verification. This allows an unauthenticated remote attacker to bypass signature validation entirely and spoof arbitrary ActivityPub actors.

Proof of Concept (PoC):

An unauthenticated remote attacker constructs a forged ActivityPub request targeting an administrative endpoint. The attacker attaches an invalid or malformed RSA signature that triggers a parsing error inside the OpenSSL library. The application receives a -1 status from the underlying openssl_verify function call and misinterprets this error state as a validation success. This grants the attacker unauthorized access to administrative functions by spoofing trusted federated identity headers.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52767>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52767>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52767>

CVE-2026-53932

Finding: OS Command Injection in laravel-backup-restore

CVSS v3.1 Score: 8.0 | Severity: Unknown | Urgency Score: 72/100 | CWE: CWE-77

Score Provenance: Unverified
MITRE ATT&CK: T1059, T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

The laravel-backup-restore package is vulnerable to an OS command injection vulnerability during database restoration operations. The application invokes shell utilities using unsanitized file paths or configurations provided by the user. An attacker can exploit this behavior to execute arbitrary system commands with the privileges of the web application server.

Proof of Concept (PoC):

An authenticated attacker with restore permissions uploads a database backup file with a shell metacharacter in its filename. The attacker triggers the database restore procedure through the laravel-backup-restore UI. The underlying package constructs a shell command utilizing the raw filename string without sanitizing shell-special characters. This triggers execution of the embedded system commands on the host server during the command run.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53932>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53932>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53932>

CVE-2026-52770

Finding: SQL Injection in YesWiki Bazar APIs

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-89

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

YesWiki is vulnerable to an SQL injection vulnerability in its public Bazar entry-listing APIs. The filters using query and queries do not enforce strict numerical validation or parameterization before appending them to SQL queries. This allows unauthenticated remote attackers to execute arbitrary database queries, leading to unauthorized read access to sensitive records.

Proof of Concept (PoC):

An unauthenticated remote attacker accesses the public Bazar entry-listing API endpoint. The attacker sends a GET request appending boolean-based SQL injection strings inside the queries filter parameter. The server-side script fails to validate that the filter is purely numeric and passes it directly to the query planner. This returns database output indicating query evaluation, exposing protected user tables and system configurations.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52770>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52770>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52770>

CVE-2026-53727

Finding: SSRF and Local File Disclosure in Ruby CSS Parser

CVSS v3.1 Score: 7.5 | Severity: Unknown | Urgency Score: 68/100 | CWE: CWE-918

Score Provenance: Unverified

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Ruby CSS Parser package is vulnerable to a Server-Side Request Forgery and Local File Disclosure flaw within its read_remote_file method. The parser does not restrict CSS @import resource locations, allowing it to request internal hosts or read local files. This enables a remote attacker to read sensitive host files or scan internal local services.

Proof of Concept (PoC):

An unauthenticated remote attacker submits a CSS stylesheet for remote processing containing a crafted @import rule. The attacker sets the target URL of the @import directive to an internal sensitive path, such as file:///etc/passwd. The server parses the stylesheet and executes the read_remote_file method without validating the URI scheme. This causes the parsed output to contain the contents of the local file, which is returned to the attacker.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53727>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53727>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53727>

CVE-2026-52762

Finding: Server-Side Template Injection in YesWiki Bazar Templates

CVSS v3.1 Score: 7.2 | Severity: Unknown | Urgency Score: 65/100 | CWE: CWE-1336

Score Provenance: Unverified

MITRE ATT&CK: T1059.003

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	High
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

YesWiki is vulnerable to a server-side template injection vulnerability in its Bazar semantic template component. The system fails to sanitize input rendered inside templates, allowing administrators to execute arbitrary code on the underlying host. An attacker with administrative privileges can utilize this path to compromise the web server.

Proof of Concept (PoC):

An authenticated administrator accesses the Bazar Semantic Template configuration interface. The attacker inserts a

malicious template payload containing system execution commands. The server processes the template utilizing a vulnerable rendering engine without sandbox restrictions. This executes the command chain within the underlying operating system context, giving the attacker terminal access.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52762>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52762>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52762>

CVE-2026-53637

Finding: Unauthorized Modification of Completed Orders in Sylius

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-672

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1565

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	Low	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	High	Availability Impact	None

Description:

The Sylius Cart FormComponent incorrectly permits the modification or deletion of orders that have already been finalized and completed. The underlying system does not validate the state of an order before processing modifications submitted via the cart interface. This allows an authenticated user to alter historical transaction records, causing significant data integrity issues and potential financial fraud.

Proof of Concept (PoC):

An authenticated user navigates to their completed order history within the Sylius platform. The attacker intercepts and modifies the Cart FormComponent submission payload to target an already completed order ID. The server receives the update request and executes the status or item modification without verifying that the targeted order is locked and completed. This results in the retrospective alteration or deletion of a legally finalized transaction.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53637>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53637>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53637>

CVE-2026-52763

Finding: SQL Injection in YesWiki Recent Changes Action

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-89

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	Low	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High

Integrity Impact

None

Availability Impact

None

Description:

YesWiki is vulnerable to an SQL injection vulnerability within its recentchanges rendering action. The period query parameter is processed and appended to active SQL statements without sanitization or data-type coercion. This allows an attacker to manipulate the query flow to read sensitive data directly from the system database.

Proof of Concept (PoC):

An authenticated remote attacker requests a page containing the recentchanges action. The attacker includes arbitrary SQL syntax within the period argument of the request payload. The application integrates the unescaped argument into the SQL string used to retrieve history information. The server executes this modified database query, exposing sensitive tables and credentials to the attacker.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52763>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52763>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52763>

CVE-2026-53769

Finding: Missing Upload Authorization in Avo

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-862

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1548

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

Avo is vulnerable to an authorization bypass vulnerability in its direct attachment upload endpoint. The endpoint lacks necessary authorization checks, enabling users to upload files and bypass configured field-level upload policies. This allows unauthorized users to upload files to storage, potentially leading to resource consumption or hosting of malicious files.

Proof of Concept (PoC):

An authenticated remote attacker targets the Avo direct attachment upload endpoint. The attacker uploads a file payload directly via this endpoint bypassing standard field-level checks. The application accepts the file and writes it to cloud storage without enforcing the defined access or upload policies. This allows the attacker to bypass specific restriction rules and write unauthorized data directly into the system's storage backend.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53769>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53769>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53769>

CVE-2026-53602

Finding: Non-Durable Host Revocation in Nebula Mesh

CVSS v3.1 Score: 9.1 | Severity: Unknown | Urgency Score: 59/100 | CWE: CWE-613

Score Provenance: Unverified

MITRE ATT&CK: T1556

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Nebula Mesh is vulnerable to an authentication bypass where host revocation is not durable. The system allows blocked or offboarded hosts to regain or utilize valid certificates due to improper session and lifetime tracking. This allows revoked hosts to re-authenticate and access the private overlay network, compromising network isolation.

Proof of Concept (PoC):

A previously revoked host attempts to reconnect to the Nebula Mesh overlay network. The host submits an expired or blocked token parameter during the initial certificate exchange process. The mesh controller processes the connection but fails to dynamically reference the revocation status on subsequent re-issuances. This allows the revoked host to successfully negotiate a new valid session key and join the private network segment.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53602>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53602>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53602>

CVE-2026-52774

Finding: Reflected Cross-Site Scripting in YesWiki Bazar Widget

CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 55/100 | CWE: CWE-80

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1059.007

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

YesWiki contains a reflected cross-site scripting vulnerability due to the failure to sanitize user input within the Bazar widget. The application reflects the unescaped id parameter directly into HTML attributes generated by the widget interface. This allows a remote attacker to execute arbitrary JavaScript code in the browser context of an unsuspecting user who clicks a malicious link.

Proof of Concept (PoC):

An unauthenticated attacker crafts a malicious URL targeting the Bazar widget containing a JavaScript payload in the id parameter. The attacker social-engineers a victim into clicking this link. The YesWiki platform renders the webpage, injecting the unescaped payload directly into the widget's HTML tag attributes. This triggers the execution of the attacker's script in the victim's browser session, facilitating session hijacking.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52774>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52774>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52774>

CVE-2026-52773

Finding: Reflected XSS in YesWiki Revision Handler

CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 55/100 | CWE: CWE-80

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1059.007

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

The YesWiki template rendering logic in handlers/page/show.php is vulnerable to reflected cross-site scripting. The script fails to sanitize or HTML-encode the user-controlled archived-revision time parameter before presenting it back to the client. This vulnerability enables attackers to run malicious scripts inside a target user's session to steal cookies or alter page content.

Proof of Concept (PoC):

An unauthenticated attacker creates a malicious link pointing to handlers/page/show.php with a script embedded in the time parameter. The attacker delivers this URL to an authenticated administrator of the wiki. The server processes the request and embeds the unescaped revision time value directly into the HTML structure of the page. The administrator's browser executes the script, allowing the attacker to perform unauthorized administrative actions silently.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52773>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52773>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52773>

CVE-2026-52772

Finding: Stored Cross-Site Scripting in YesWiki Bazar Templates

CVSS v3.1 Score: 5.5 | Severity: Unknown | Urgency Score: 50/100 | CWE: CWE-79

Score Provenance: Unverified
MITRE ATT&CK: T1059.007

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	High
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

YesWiki is vulnerable to stored cross-site scripting due to the use of unsafe rendering filters in Bazar form-field

templates. The Twig engine processes the field.label and field.hint parameters with a |raw('html') filter, bypassing automatic output escaping. This allows an authenticated user with form-creation privileges to store malicious scripts that execute in the context of any user viewing the form.

Proof of Concept (PoC):

An authenticated user with template-editing privileges accesses the Bazar form configuration dashboard. The attacker submits a form modification request containing a script payload in the field.label input. The server stores this configuration value in the database and renders it in the web interface utilizing the |raw('html') template filter. When other users navigate to view the generated Bazar form, their browser executes the stored payload.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52772>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52772>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52772>

CVE-2026-53760

Finding: Cross-Site Request Forgery in Admidio Plugins

CVSS v3.1 Score: 5.2 | Severity: Unknown | Urgency Score: 47/100 | CWE: CWE-352

Score Provenance: Unverified

MITRE ATT&CK: T1204.001, T1566

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:R/S:U/C:N/I:H/A:L

Attack Vector	Network
Privileges Required	High
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	None
Availability Impact	Low

Description:

Admidio is vulnerable to cross-site request forgery within its plugin management interface. The system processes installation, uninstallation, and update requests via GET requests without validating anti-CSRF state tokens. This enables an attacker to force an authenticated administrator to execute arbitrary plugin lifecycle changes via a crafted hyperlink.

Proof of Concept (PoC):

An unauthenticated attacker constructs a malicious HTML webpage targeting the Admidio plugin action. The attacker triggers an administrative action by embedding a URL like /adm_program/modules/plugins/plugins_install.php?plugin=malicious inside an image source tag. The administrator, logged into their Admidio session, visits the attacker-controlled page. This forces the server to execute the plugin installation under the administrator's context.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53760>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53760>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53760>

CVE-2026-53638

Finding: Payment Method Restriction Bypass in Sylus

CVSS v3.1 Score: 4.3 | Severity: Medium | Urgency Score: 39/100 | CWE: CWE-863

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1548

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

The Sylius shop account orders API endpoint is vulnerable to a channel-based payment method restriction bypass. The application fails to properly enforce defined payment method constraints associated with specific channels during the order processing phase. This allows an authenticated buyer to select and utilize unauthorized payment methods, compromising business logic integrity and potentially leading to financial discrepancies.

Proof of Concept (PoC):

An authenticated remote buyer logs into the Sylius shop front-end. The attacker submits a modified checkout request to the shop account orders API endpoint containing a payment method ID restricted in the current channel. The server processes the API request without verifying if the payment method is active or permitted for the selected channel. This allows the attacker to successfully complete the transaction using an unapproved or restricted payment method.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53638>Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53638>Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53638>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>

- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>